13017 计算机网络与信息安全

第九章 信息安全防护基本原理

13017 计算机网络与信息安全【第九章考点解析】

考点1 简单报文认证

报文摘要：对**报文** m应用散列函数H，得到**固定长度**的散列码。

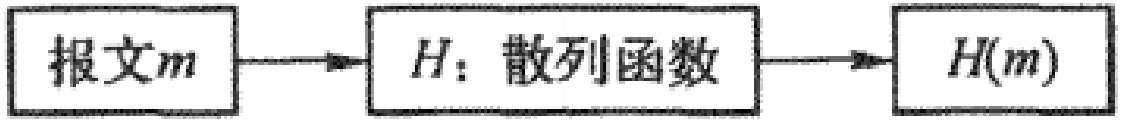


图 9-1 密码散列函数

```
[vcplat@node0 psbc-base-gateway]$
[vcplat@node0 psbc-base-gateway]$ md5sum -b psbc-base-gateway-1.0.0.jar
c84292b796fcdcfaef2524a3d37c4349 *psbc-base-gateway-1.0.0.jar
```

13017 计算机网络与信息安全【第九章考点解析】

考点1 简单报文认证

发送方：

对**报文 m** 应用散列函数 H，

获得**报文摘要 h**=H (m)，

将扩展报文 (m,H (m)) 发送给接收方。

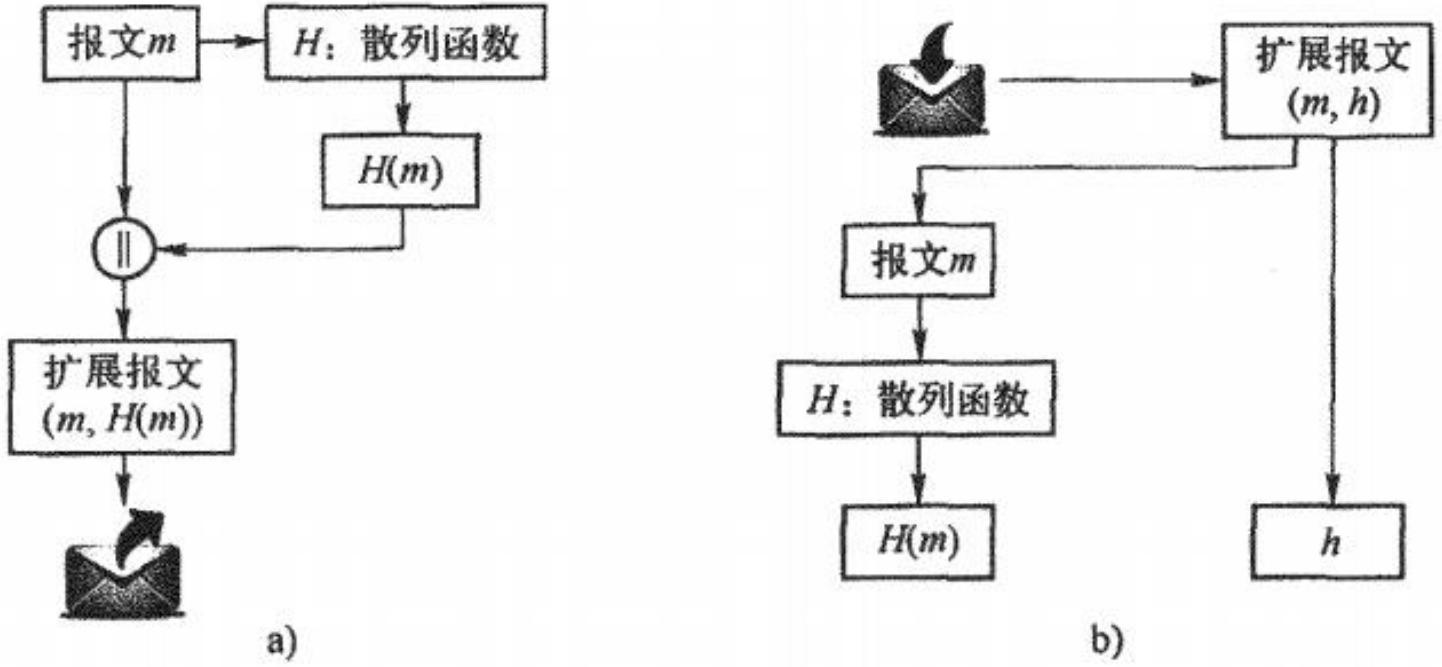


图 9-2 简单报文验证过程

接收方：

提取出**报文 m** 和**报文摘要 h**，做比较，相等，则认为报文认证成功，否则报文认证失败。

不足：无法达到对消息源认证。

13017 计算机网络与信息安全【第九章考点解析】

考点2 报文认证码（Message Authentication Code，MAC）

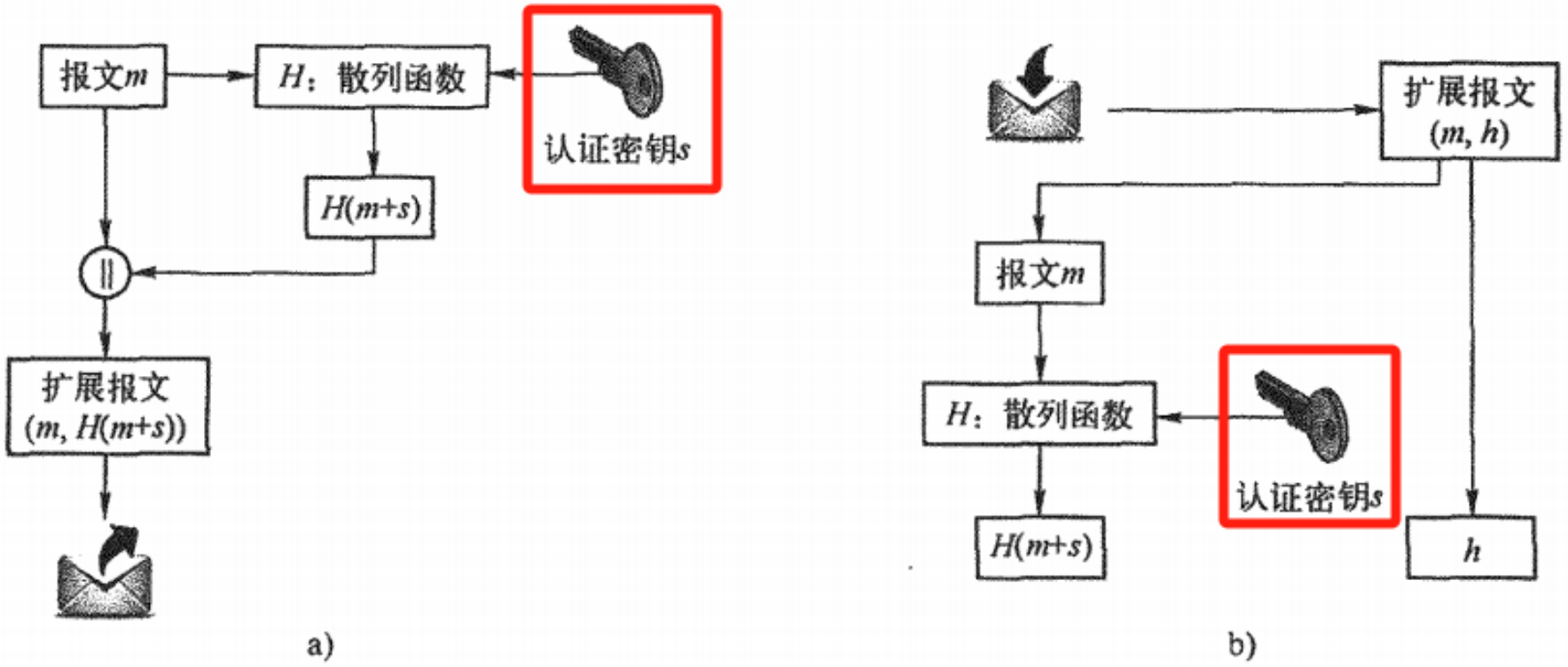


图 9-3　应用报文认证码进行报文认证过程

接收方自己写一份报文并用同样的步骤生成一份扩展报文，说这份扩展报文就是发送方发来的

不足：无法保证消息在接收方没有被篡改。

13017 计算机网络与信息安全【第九章考点解析】

考点3 数字签名

上文介绍的**两种报文认证方法**均存在不足，没办法很好地完成报文认证。在报文完整性认证的过程中，亟待解决的问题有：

1）发送方不承认自己发送过某一报文；

2）接收方自己伪造一份报文，并声称来自发送方；

3）某个用户冒充另一个用户接收和发送报文；

4）接收方对收到的信息进行篡改。

解决这些问题的有效技术手段是**数字签名**。

数字签名：在**公开密码体制**中，一个主体**使用自己的私钥加密消息**，得到的密文。密文可以使用该主体的**公钥解密**，恢复成原来的消息。如此生成的“密文”对该消息提供认证服务。

13017 计算机网络与信息安全【第九章考点解析】

考点3 数字签名

数字签名

1）简单数字签名：签名报文

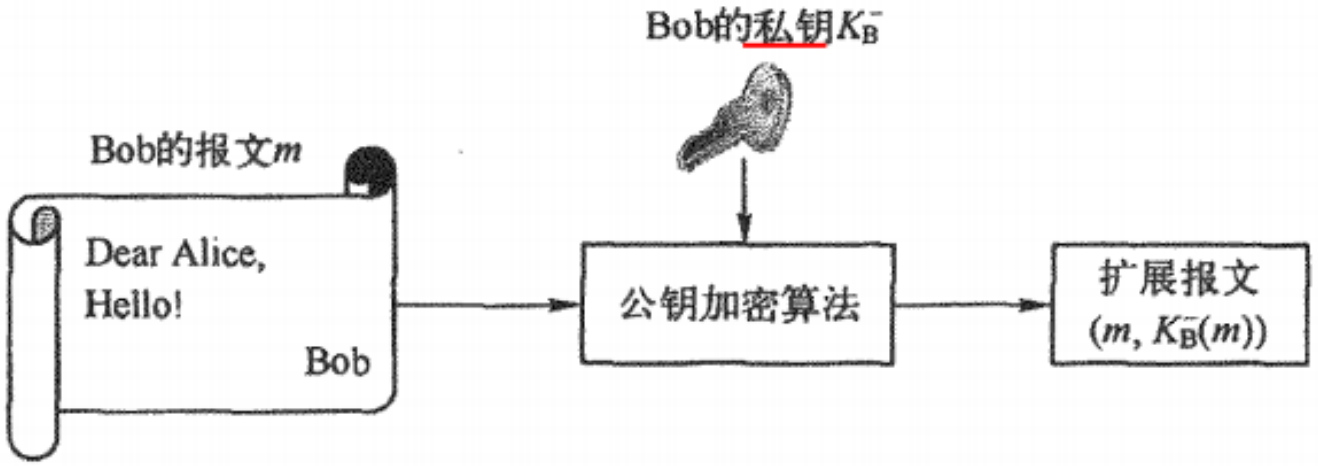


图 9-4 简单数字签名实现过程

由于数字签名利用私钥对整个报文m进行加密，造成加密算法在报文很大时计算量很大，运行效率很慢，同时生成的扩展报文数据量是原始报文的两倍多，这样就造成了接收方流量的极大浪费。

13017 计算机网络与信息安全【第九章考点解析】

考点3 数字签名

数字签名

2）签名报文摘要

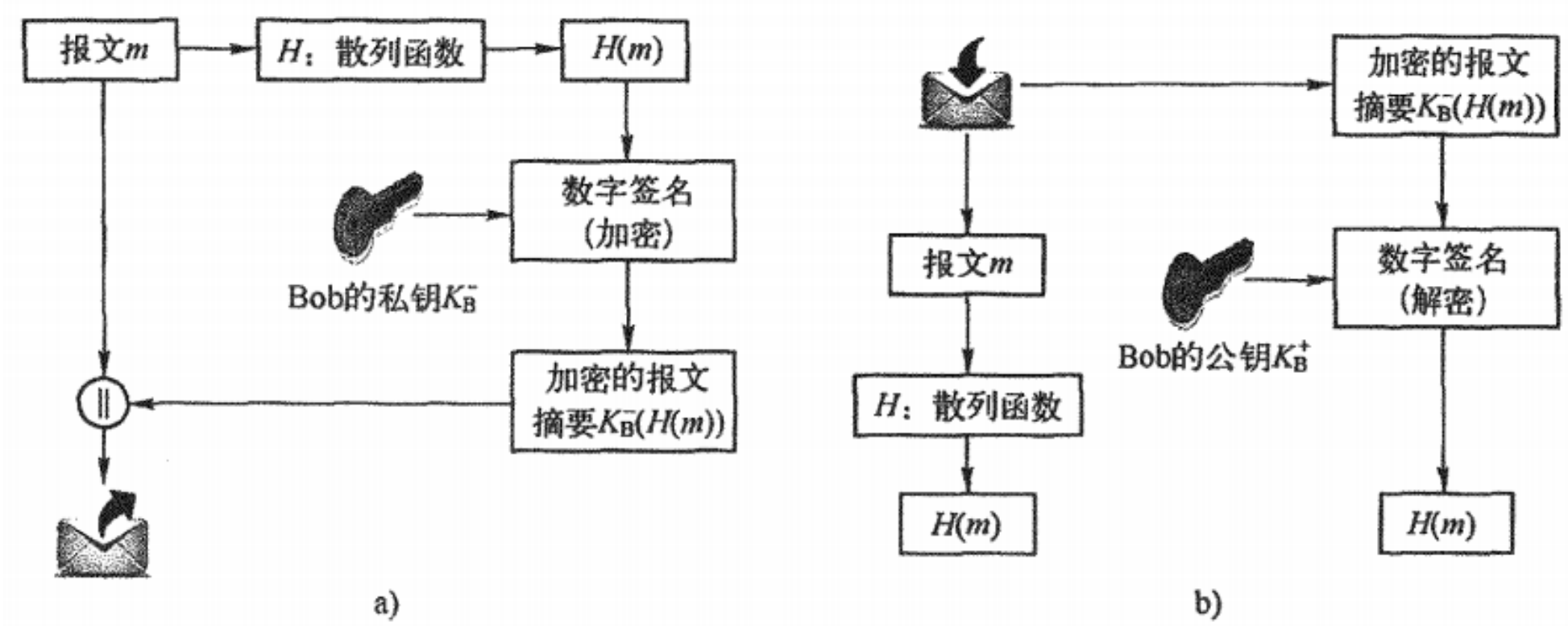


图 9-5 签名报文摘要工作流程

13017 计算机网络与信息安全【第九章考点解析】

考点4 身份认证

身份认证：身份鉴别（证明：我是我的问题）

一个实体经过计算机网络向另一个实体证明其身份的过程。

1）基于共享对称密钥的身份认证

步骤如下：

① Alice → Bob 发送报文“我是Alice ”

② Bob 选择一个一次性随机数 R 发送给Alice

③ Alice → Bob 共享的对称密钥加密 R，发回给Bob

④ Bob 解密收到的报文

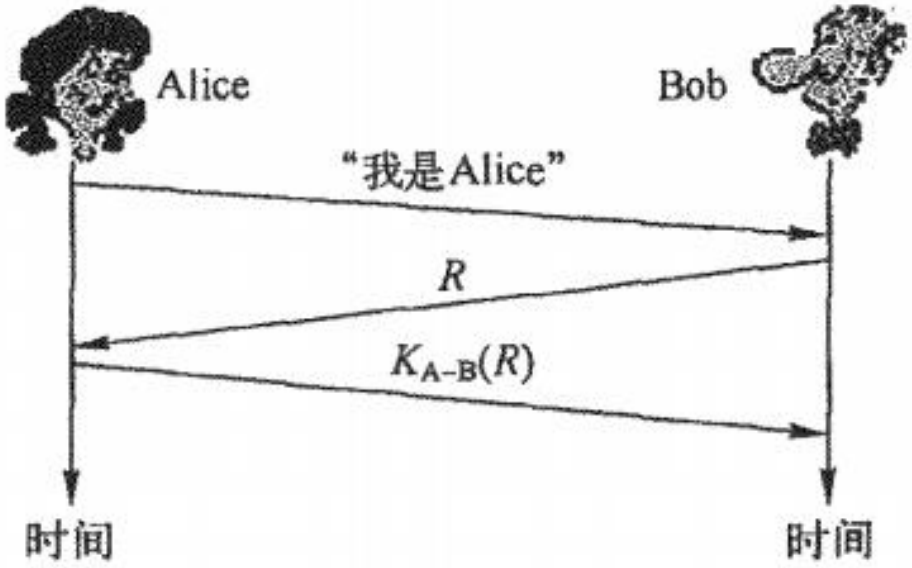


图 9-6 利用一次性随机数 R 进行身份认证

身份认证过程中通过**引入一次性随机数**可以预防重放攻击。

13017 计算机网络与信息安全【第九章考点解析】

考点4 身份认证

2）基于公开密钥的身份认证

步骤如下：

① Alice → Bob 发送报文“我是Alice ”

② Bob 选择一个一次性随机数 R 发送给Alice

③ Alice → Bob 用自己私钥加密 R，发回给Bob

④ Bob → Alice 索要她的公钥

⑤ Alice → Bob 发送自己的公钥

⑥ Bob 利用Alice的公钥解密收到的报文

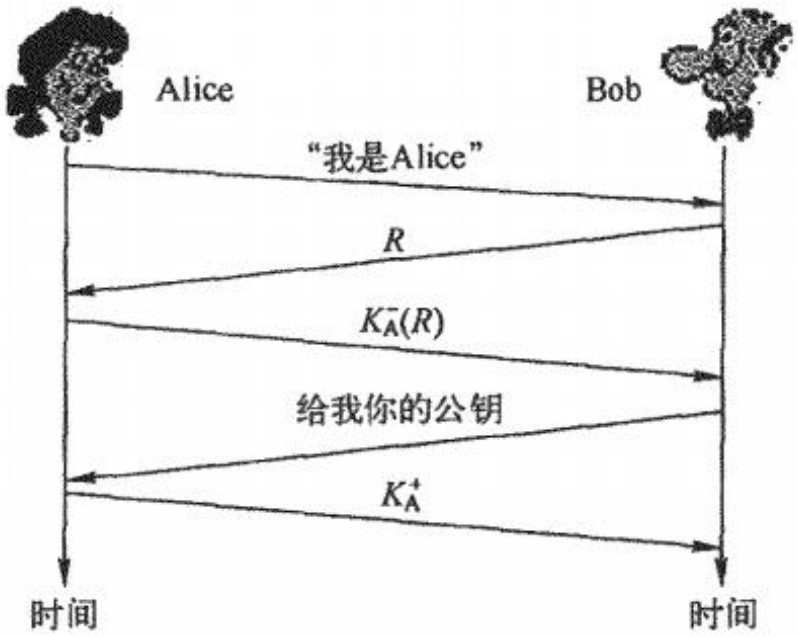


图 9-7 利用一次性随机数和公钥加密技术进行身份认证

安全漏洞：因为与**密钥的可信性**有很大关系，Trudy 将自己的公钥发给 Bob，并声称是 Alice 的公钥，Bob 没有验证公钥的真实性，于是中间人攻击就成功了。

解决这一问题的关键是要**解决（对称）密钥分发和（公开）密钥本身的认证问题。**

13017 计算机网络与信息安全【第九章考点解析】

考点5 密钥管理与分发

对称密钥分发的**典型解决方案**：通信各方建立一个大家都信赖的密钥分发中心(**Key Distribution Center，KDC**)，解决对称密钥安全可靠的分发。

证书认证机构

认证中心（**Certification Authority，CA**）的作用：

1）CA可以证实一个实体的真实身份。

2）一旦CA验证了某个实体的身份，CA会生成一个把其身份和实体的公钥绑定起来的证书，其中包含该实体的公钥及其全局唯一的身份识别信息等，并由CA对证书进行数字签名。

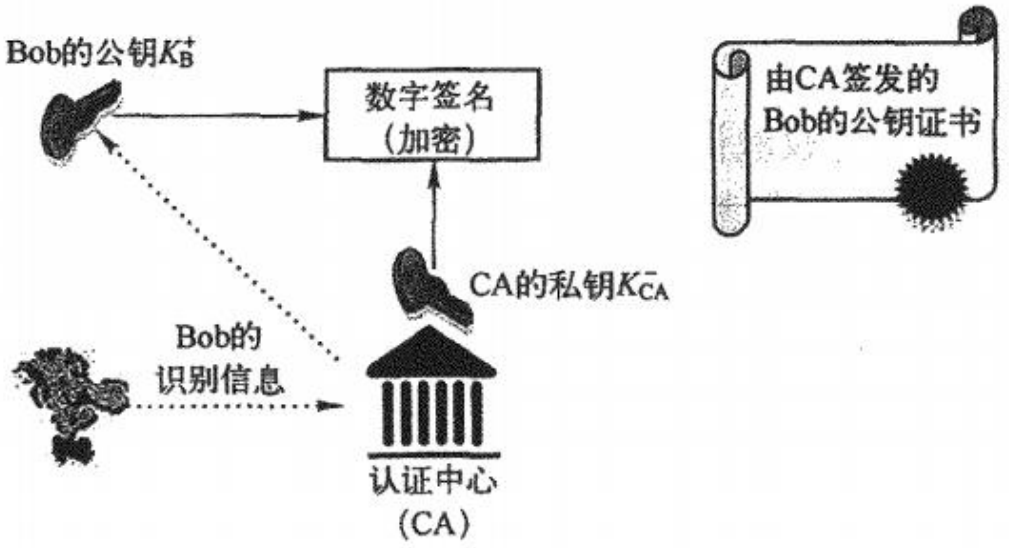


图 9-12 Bob 获取个人公钥证书的过程

13017 计算机网络与信息安全【第九章考点解析】

考点6 PKI

PKI（**Public Key Infrastructure**，公钥基础设施）是一种遵循标准的利用公钥加密技术为电子商务的开展提供一套安全基础平台的技术和规范。

PKI 技术是信息安全技术的核心，也是电子商务的**关键**和**基础**技术。

PKI 的**基础技术**包括加密、数字签名、数据完整性机制、数字信封、双重数字签名等。

24. PKI 的基础技术包括加密、_____、数据完整性机制、数字信封、双重数字签名等。

答案：数字签名【2024年10月】13017

13017 计算机网络与信息安全【第九章考点解析】

考点7 访问控制

访问控制的目标是防止对**任何**计算机资源、通信资源或信息资源进行未授权的访问。

访问控制应具有以下 3 个功能。

1）识别和确认访问系统的用户。

2）资源访问权限控制功能，决定用户对系统资源的访问权限。

3）审计功能，记录系统资源被访问的时间和访问者信息。

访问控制包括3 个要素：主体、客体和访问控制策略

访问控制策略包括自主访问控制、强制访问控制和基于角色的访问控制等。

例题1：访问控制的**目标**是防止对任何计算机资源、通信资源或信息资源进行__未授权__的访问。

例题2：**访问控制策略**包括自主访问控制、强制访问控制和__基于角色的访问控制__等。

13017 计算机网络与信息安全【第九章考点解析】

考点8 内容安全

信息内容安全主要包含两方面内容：

1）针对合法的信息内容，应安全保护，如：对合法的音像制品及软件的版权保护；

2）针对非法的信息内容，应实施监管，如：对网络色情信息的过滤等。

DRM 技术就是以一定的安全算法实现对数字内容的保护，包括电子书（eBook）、视频、音频、图片等数字内容。

例题1：信息内容安全主要包含两方面内容：合法的信息内容和__非法__的信息内容。

13017 计算机网络与信息安全【第九章考点解析】

考点9 物理安全

物理安全包括环境安全、电磁保护、物理隔离及安全管理。

例题1：物理安全包括环境安全、电磁保护、__物理隔离__及安全管理。

谢 谢 大 家